Cyber Attacks

Unit: What Is Security?

Problem Area: Security Risks

Lesson: Cyber Attacks

Student Learning Objectives.

Instruction in this lesson should result in students achieving the following objectives:

1. **Explain types of cyber attacks.**
2. **Summarize attack protection methods.**

Resources.

The following resources may be useful in teaching this lesson:

E-unit(s) corresponding to this lesson plan. CAERT, Inc. http://www.mycaert.com.

Brown, Ian. "Cybersecurity Lab Guide for Educators," *NOVA Labs, PBS, WTTW*. Accessed Oct. 6, 2016. http://www.pbs.org/wgbh/nova/labs/about-cyber-lab/educator-guide/.

"Cyber Attack," *ready.gov*. Accessed Oct. 6, 2016. https://www.ready.gov/cyber-attack.

"Internet Crime Complaint Center (IC3)," *Federal Bureau of Investigation (FBI)*. Accessed Oct. 6, 2016. https://www.ic3.gov/default.aspx.

Rizzo, Tom. "3 Types of Password Attacks and How to Avoid Them," *AuthAnvil*. Accessed Oct. 6, 2016. http://insights.scorpionsoft.com/3-types-of-password-security-attacks-and-how-to-avoid-them.

"Types of Attacks," *Penn State Personal Web Server*. Accessed Oct. 6, 2016. http://www.personal.psu.edu/users/j/m/jms6423/Engproj/Types%20of%20Attacks.xhtml.

"What Is the Difference: Viruses, Worms, Trojans, and Bots?" *Cisco*. Accessed Oct. 6, 2016. http://www.cisco.com/c/en/us/about/security-center/virus-differences.html.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Equipment, Tools, Supplies, and Facilities

- ✓ Overhead or PowerPoint projector
- ✓ Visual(s) from accompanying master(s)
- ✓ Copies of sample test, lab sheet(s), and/or other items designed for duplication
- ✓ Materials listed on duplicated items
- ✓ Computers with printers and Internet access
- ✓ Classroom resource and reference materials

Key Terms. The following terms are presented in this lesson (shown in bold italics):

- advanced persistent threat (APT)
- adware
- AutoRun
- bot
- botnet
- brute-force attack
- CDN
- cyber attack
- DDoS
- dictionary attack
- DoS
- hacking
- keylogger
- logic bomb
- malware
- MitM
- password attack
- patches
- phishing
- pineapple
- PoLP
- proxy server
- ransomware
- rootkit
- round robin DNS
- scareware
- spam
- Trojan horse
- two-factor authentication
- virus
- worm

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Interest Approach. Use an interest approach that will prepare the students for the lesson. Teachers often develop approaches for their unique class and student situations. A possible approach is included here.

> *Tell students, "Most people have some type of experience with cyber attacks. Today, we worry about viruses on our computers, malware on our smartphones, and neighbors stealing our Wi-Fi signals!" Ask, "What are types of cyber attacks, and how can we protect against them?" Project VM–A for an overall "look" at computer crime.*

CONTENT SUMMARY AND TEACHING STRATEGIES

Objective 1: Explain types of cyber attacks.

Anticipated Problem: What is a cyber attack? What are types of cyber attacks? How are cyber attacks differentiated?

I. Cyber attack types

A. A ***cyber attack*** is an electronic maneuver on a computer system aimed at either destroying information and/or property or stealing information. Common threats include spam, hacking, and phishing. ***Spam*** is mass undesirable, unsolicited email (a form of bulk email) that attacks productivity, bandwidth, and disk space and may be a method for delivering malware. ***Hacking*** is the process a cyber criminal uses to access a computer. ***Phishing*** is a scam in which fake emails, text messages, and websites are created to look as if they were originated by a genuine company. [See VM–B for a poster depicting types of cyber crimes.]

B. ***Malware*** (short for "malicious software") is a program designed to damage or harm a computer system. [See VM–C for an illustration of various types of malware.] Malware is divided into several categories, including the following:

1. A ***virus*** is malware that attaches to a program and self-replicates once the host program has been executed (started). The virus can grow and infect other files and programs.
2. A ***worm*** is malware very similar to a virus but can replicate without being attached to an .exe file. Worms take advantage of vulnerabilities in the host system or use social engineering to trick victims into starting them.
3. A ***Trojan horse*** is a malicious malware code that, once inside the computing device, can execute whatever task the attacker created. Trojans are often hidden in email attachments that look like legitimate files or programs, and users are tricked into starting the malicious malware. However, Trojans do not self-

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

replicate or propagate without the end user's help. Trojans are named after the Trojan horse of Greek mythology.

4. A ***bot*** (short for "web-robot") is an automated process that can be programmed to replicate, log keystrokes, and/or launch attacks. Bad bots consume bandwidth, slow down servers, steal content, and look for vulnerabilities. Bots are highly versatile. Bots are not necessarily bad and can also be used to automate information services for benign reasons.
5. A ***rootkit*** is a utility used to conceal malicious activity: it allows an unauthorized user administrative access to a computer and hides itself so that it is very hard to find. Rootkit operators can remotely execute files and change computer configurations. Rootkits are difficult to detect.
6. ***Ransomware*** is malicious malware that limits access to valuable files (kidnaps the files) that belong to the victim until a fee (ransom) has been paid. An attacker may encrypt the victim's data, lock the hard drive, or lock the system and display messages to coax the user into paying. Ransomware typically enters through an infected phishing link embedded in an email or download, then demands a ransom to release the "locked files." [See VM–D for an illustration of the ransomware concept.]
7. ***Adware*** is a software application that involves advertisement banners that display while the program is running; the unwanted ads collect information and marketing data from the user. This information is often collected and sold without the user's permission.
8. ***Scareware*** is malware that frightens or tricks a user into downloading or buying software that is not needed. Often, a false warning will appear on the user's computer.

C. Denial of service attacks

1. ***DoS*** (denial of service) is an attack that deprives a user of service by flooding the victim's machine or network with incoming illegitimate requests and traffic. In a DoS attack, the system is so busy that the resource in question is unavailable.
2. ***DDoS*** (distributed denial of service) is a DoS attack that uses many IP addresses—sometimes thousands, sometimes hundreds of thousands—that flood the system. A DDoS attack makes it nearly impossible to block offending IP addresses. [See VM–E for an illustration of the DoS and DDoS.]
3. A ***botnet*** is a bot running on a network using many computers, networked together, to coordinate an action. Botnets are often created with a Trojan and are often used in DDoS attacks.

D. Other cyber attacks

1. A ***password attack*** is any assault aimed at discovering a victim's password and logging in. Usually, this is with the intent of theft of information or money.
   a. A ***brute-force attack*** is an attack in which a hacker tries password combinations, through trial and error or with a computer program, until the correct password is learned.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

b. A ***dictionary attack*** is a method of breaking into a password-protected computer or server by using a program that tries every word in the dictionary or by using a combination of common words.

c. A ***keylogger*** is software that secretly captures each keystroke typed on a keyboard by attaching itself to an API (application programming interface). Using a keylogger, a cyber criminal is able to gather username and password information.

2. ***MitM*** (man-in-the-middle) is a type of electronic eavesdropping in which a communication between two parties is stopped by a "middleman" and altered. MitM is a security issue. A ***pineapple*** is a version of man-in-the-middle in which the victim is fooled into thinking he or she is accessing Wi-Fi but is actually connecting to an attacker's network.

3. An ***advanced persistent threat (APT)*** is a hacking attack conducted over an extended period for a specific purpose. This type of attack is labeled "advanced persistent" because the attackers must be advanced to remain unnoticed for a long time. This type of attack is usually conducted for the purposes of activism or for political or espionage reasons.

4. A ***logic bomb*** is programming code inserted (often maliciously) to execute (explode) based on a trigger: time passing or the user's failure to respond to a command. It is sometimes likened to a delayed-action virus or a Trojan horse inserted with the intent of damaging a computer or network. Logic bombs explode at a specific time of day or when a specific event or condition occurs (e.g., a login).

Teaching Strategy: *Many techniques can be used to help students master this objective. Use VM–B through VM–E to review features and concepts and to differentiate types of cyber attacks. Assign LS–A.*

Objective 2: Summarize attack protection methods.

Anticipated Problem: What techniques, tools, and policies are used to protect against cyber attacks?

II. Cyber attack protection methods

A. EMPLOYEE EDUCATION: Employee education is one of the best protection methods against cyber attacks. For example:

1. Passwords aren't fun to keep current and keep track of, but with good practices they still work very well and are often the first line of defense. Recommendations include:

a. Enhancing password strength with length and special characters. Common words should not be used unless their spelling has been modified with numbers and special characters.

b. Changing passwords as often as can be tolerated.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

c. Mandating that employees work passwords are not used for any other website or service.

2. Handling email properly and recognizing spam are increasingly important skills. Malware takes advantage of email and email attachments to "take hold" in a network. Recommendations include:
   a. Not opening attachments unless absolutely sure of the sender and the content.
   b. Being wary of links within an email. These are often false links that lead to false websites or that execute malware. **NOTE:** Employees should make a practice of typing website destinations into the address bar themselves.
   c. Learning to recognize false emails: scams. If an email is asking for personal information, asking a user to download something, or requiring payment, one should be very wary—especially if such an email comes unsolicited.

B. UPDATES: Keeping all software, antivirus programs, and operating systems updated is recommended. Frequent updates help protect against the latest malware. As large companies learn about vulnerabilities within their software, they send out ***patches*** (security updates that fix specific problems related to products installed on a device, such as security holes or bugs). Updates for antivirus or antispyware software help protect customers. One should take advantage of the companies' hard work by auto-updating!

C. BACKUPS: All sensitive information should be backed up and backed up often. Backing up data protects against massive damage from malware and, more specifically, from ransomware. Recommendations include:
   1. Keeping a second set of records in the cloud.
   2. Keeping a set of offline records (hardcopy, flash drive, etc.). Offline records are the most secure type of backup. [See VM–F for an illustration of devices used to back up files.]

D. INFORMATION TECHNOLOGY (IT) DEPARTMENT PROTECTIONS: Some forms of cyber protection need to come from the company's IT department. Expecting the average employee to have expertise in the following areas would be unwise. [See VM–G for a photo of a network technician on the job.]
   1. ***AutoRun*** is a function of the Windows operating system that automatically runs executable files when media is inserted. RECOMMENDATION: Disabling AutoRun will stop some types of malware from running automatically; it is a recommended strategy. (**NOTE**: The directions to disable AutoRun with various Windows products are fairly straightforward and easy to find with a quick Internet search.)
   2. The ***PoLP*** (principle of least privilege) is a computer security concept that maintains computer users should have just enough access to their workstations and the network to perform their jobs. RECOMMENDATION: The PoLP should be practiced with user accounts. Extra access or privileges should not be given unless absolutely required to conduct the job. The administrator functions of each computer should be locked.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

3. A ***proxy server*** is a server that acts as an intermediary between a device on a network system and the Internet at large. A proxy server also hides the IP address of the user's computer. RECOMMENDATION: Route all Internet traffic through a proxy server.
   a. Open-source proxy server software is available, but when more robust protection is required, products can be found that mesh best with Cisco networks, Microsoft network environments, etc. [See VM–H for an illustration of a proxy server process.]
   b. A ***CDN*** (content delivery network) is a network of proxy servers in different data centers around the globe. The CDN provides faster service to the website by distributing the load across many servers, saving bandwidth and boosting performance. [See VM–I for an illustration that shows two proxy server concepts: one is single, and the other is CDN.]
4. ***Round robin DNS*** is a technique of load balancing, load distributing, or fault-tolerance provisioning for Internet services—web server, email server—by creating multiple DNS A records with the same name. In short, this means that there are multiple IP addresses for the domain name. For each user that requests access to the site, a different IP address is used based on a rotation of addresses. RECOMMENDATION: Round robin DNS should be used to add redundancy to a website and to help block DDoS attacks. Many large sites—Twitter, Google, Reddit, and Yahoo—have used (and may still use) Round robin DNS to balance their Internet traffic.

E. INFRASTRUCTURE AND INTERNAL POLICIES: Infrastructure and internal policies may go beyond what average IT workers can decide for themselves. The following are policies or services that a company may feel should be implemented to create additional levels of security.

1. ***Two-factor authentication*** is a security mechanism that requires two types of user credentials for verification—typically, (1) physical validation and (2) a logical code. An example is using a password and an additional method, such as a security token, when logging into a secure system. RECOMMENDATION: Implementing a two-factor authentication protocol is wise. Doing so adds another level of security and offers much more protection than a password alone. [See VM–J for an illustration of a popular two-factor authentication method.]
2. Encrypting (encoding) all traffic between the server and client computers is a consideration for every company. Several software options for servers are available that meet this need.
3. Changing business websites from HTTP (HyperText Transfer Protocol) to HTTPS (HyperText Transfer Protocol Secure) helps ensure that user data and information cannot be stolen. In HTTPS, sending and receiving computers agree on a code known only to them and then scramble the messages using that code so that no one in between can read them. This keeps information safe from hackers. The process entails buying and activating an SSL (Secure Sockets Layer) certificate.
4. Protecting against the accidental installation of malware may require a policy that all software be downloaded and installed by an IT professional.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Teaching Strategy: *Many techniques can be used to help students master this objective. Use VM–F through VM–J to review features and concepts of attack protection methods. Assign LS–B.*

- **Review/Summary.** Use the student learning objectives to summarize the lesson. Have students explain the content associated with each objective. Student responses can be used in determining which objectives need to be reviewed or taught from a different angle. If a textbook is being used, questions at the ends of chapters may also be included in the Review/Summary.

- **Application.** Use the included visual masters and lab sheets to apply the information presented in the lesson.

- **Evaluation.** Evaluation should focus on student achievement of the objectives for the lesson. Various techniques can be used, such as student performance on the application activities. A sample written test is provided.

- **Answers to Sample Test:**

Part One: Matching

1. b
2. e
3. f
4. c
5. a
6. d

Part Two: Multiple Choice

1. b
2. b
3. d
4. c
5. a
6. d

Part Three: True/False

1. T
2. T
3. T
4. F
5. F
6. F

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Sample Test

Name _____

Cyber Attacks

Part One: Matching

Instructions: **Match the term with the correct definition.**

a. pineapple
b. DoS
c. advanced persistent threat (APT)
d. AutoRun
e. Trojan horse
f. PoLP

_____1. An attack that deprives a user of service by flooding the victim's machine or network with incoming illegitimate requests and traffic.

_____2. A malicious malware code that, once inside the computing device, can execute whatever task the attacker created.

_____3. A computer security concept that maintains computer users should have just enough access to their workstations and the network to perform their jobs

_____4. A hacking attack conducted over an extended period for a specific purpose

_____5. A version of man-in-the-middle in which the victim is fooled into thinking he or she is accessing Wi-Fi but is actually connecting to an attacker's network

_____6. A function of the Windows operating system that automatically runs executable files when media is inserted

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Part Two: Multiple Choice

Instructions: **Circle the letter of the correct answer.**

1. Malware that attaches to a program and self-replicates once the host program has been executed (started) is a _____.

   a. DoS
   b. virus
   c. MitM
   d. worm

2. _____ is a software application that involves advertisement banners that display while the program is running; the unwanted ads collect information and marketing data from the user.

   a. DoS
   b. Adware
   c. Scareware
   d. Ransomware

3. An attack in which a hacker tries password combinations, through trial and error or with a computer program, until the correct password is learned is a _____.

   a. dictionary attack
   b. password attack
   c. cyber attack
   d. brute-force attack

4. _____ is a type of electronic eavesdropping in which a communication between two parties is stopped by a "middleman" and altered.

   a. APT
   b. DoS
   c. MitM
   d. DDoS

5. A security mechanism that requires two types of user credentials for verification is _____.

   a. two-factor authentication
   b. MitM
   c. APT
   d. DDoS

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

6. Malicious malware that limits access to valuable files that belong to the victim until a fee has been paid is _____.

   a. scareware
   b. APT
   c. adware
   d. ransomware

Part Three: True/False

Instructions: **Write *T* for true or *F* for false.**

_____1. Patches are security updates that fix specific problems related to a product installed on a device, such as security holes or bugs.

_____2. A proxy server is an intermediary between the network system and the Internet at large.

_____3. Spam is unsolicited email that attacks your productivity, bandwidth, and disk space and may be a method for delivering malware.

_____4. Two-factor authentication is a network of proxy servers in different data centers around the globe.

_____5. Scareware is any program created for criminal or malicious reasons.

_____6. A keylogger is any program created for criminal or malicious reasons.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

COMPUTER CRIME

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

CYBER ATTACKS

A cyber attack is an electronic maneuver on a computer system aimed at either destroying information and/or property or stealing information.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

MALWARE

Malware (short for “malicious software”) and is a program designed to damage or harm a computer system. Examples are viruses, worms, Trojan horses, and bots.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

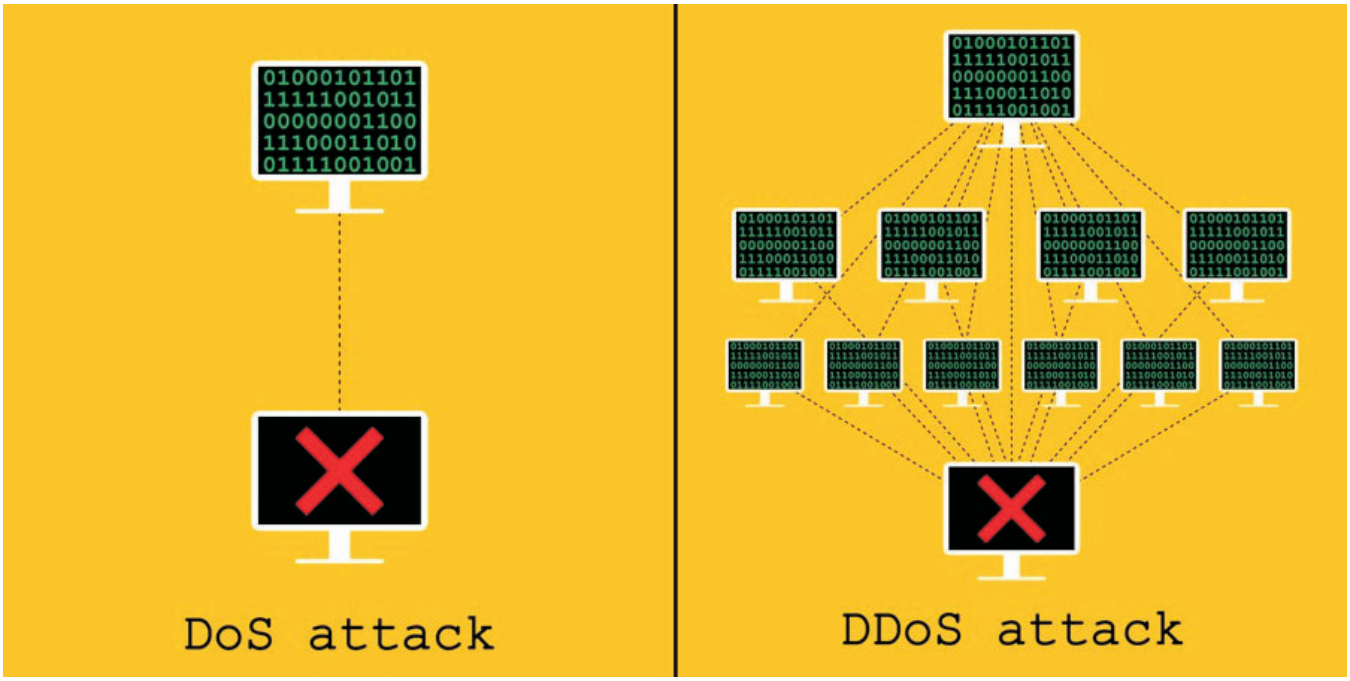
RANSOMWARE

Ransomware is malicious malware that limits access to valuable files (kidnaps the files) that belong to the victim until a ransom has been paid. An attacker may encrypt the victim's data, lock the hard drive, or lock the system and display messages to coax the user into paying.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

DoS AND DDoS ATTACKS

DoS (denial of service) is an attack that deprives a user of service by flooding the victim's machine or network with incoming illegitimate requests and traffic. In a DoS attack, the system is so busy that the resource in question is unavailable. DDoS (distributed denial of service) is a DoS attack that uses many IP addresses—sometimes thousands, sometimes hundreds of thousands—that flood the system. A DDoS attack makes it nearly impossible to block offending IP addresses.



Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

DATA BACKUP

- All sensitive information should be backed up and backed up often. Backing up data protects against massive damage from malware and, more specifically, from ransomware.

- Recommendations include:

  1. Keeping a second set of records in the cloud.
  2. Keeping a set of offline records (hardcopy, flash drive, etc.). Offline records are the most secure type of backup.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

NETWORK TECHNICIAN

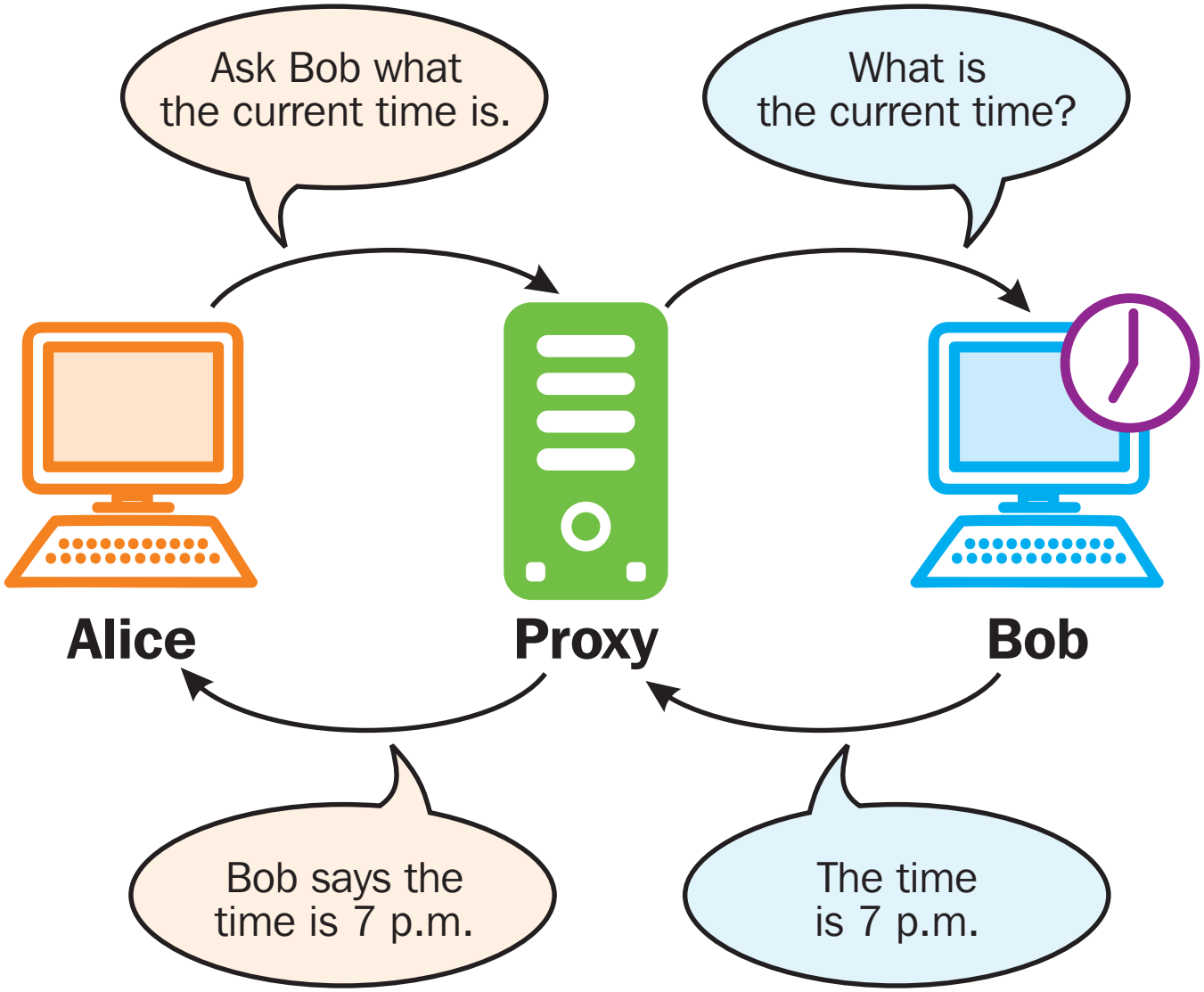
Some forms of protection need to come from the company's IT department. Expecting the average employee to have expertise in the following areas would be unwise.

- AutoRun
- PoLP
- Proxy servers
- Round robin DNS

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

PROXY SERVERS

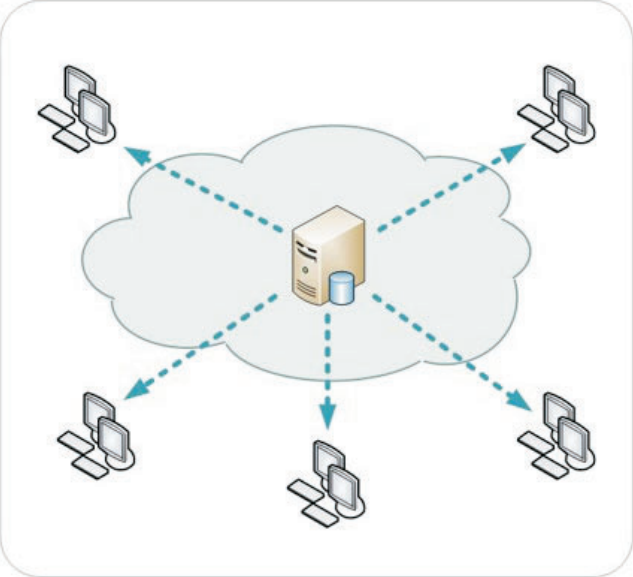
Communication between two computers (shown in orange and blue) connected through a third computer (shown in green) acting as a proxy. Bob does not know to whom the information is going, which is why a proxy can be used to protect privacy.

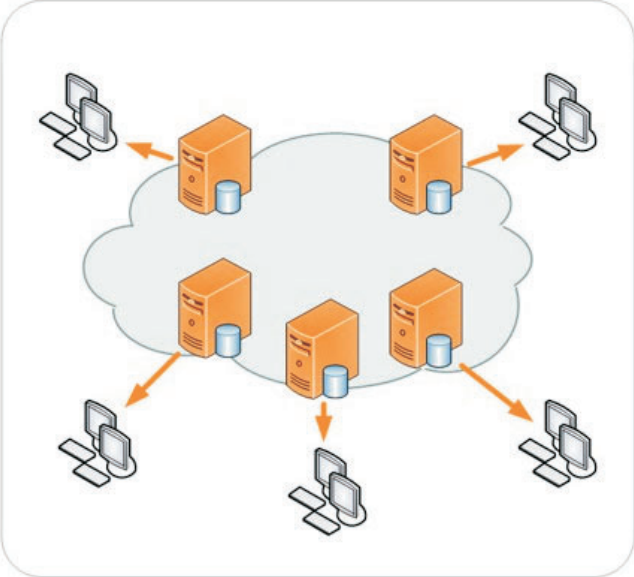


Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

CDN

A CDN (content delivery network) is a network of proxy servers in different data centers around the globe. The CDN provides faster service to the website by distributing the load across many servers, saving bandwidth and boosting performance. The network on the left (blue) is a single-server network. The network on the right (orange) is a CDN scheme of distribution. (This image is licensed under the Creative Commons Attribution-Share Alike 3.0 Unported license: https://creativecommons.org/licenses/by-sa/3.0/deed.en.)





Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

TWO-FACTOR AUTHENTICATION

Two-factor authentication is a security mechanism that requires two types of user credentials for verification—typically, (1) physical validation and (2) a logical code. An example is using a password and an additional method, such as a security token, when logging into a secure system.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

LS–A

Name _____

An Infamous Cyber Attack

Purpose

The purpose of this activity is to research and formulate a plan against an infamous cyber attack.

Objectives

1. Research an infamous cyber attack.
2. Summarize the attack.
3. Formulate a plan of defense against the attack.
4. Participate in a class discussion of others' plans of defense against the attack.

Materials

- lab sheet
- device with Internet access

Procedure

1. Work independently or with a partner to complete this lab activity.
2. TASK: Research, summarize, and formulate a plan to defend against a cyber attack. To begin your research, access the *MIT Technology Review* website for its list of the "The 20 Most Infamous Cyberattacks of the 21st Century" at:
   - Part I: https://www.technologyreview.com/s/540786/the-20-most-infamous-cyberattacks-of-the-21st-century-part-i/
   - Part II: https://www.technologyreview.com/s/540791/the-20-most-infamous-cyberattacks-of-the-21st-century-part-ii/

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Then, conduct additional research about cyber attacks, ensuring that you are accessing reputable and safe websites. Next, select an attack of interest to you. This is the cyber attack for which you will complete the remainder of this lab activity.

3. Summarize the attack in the space provided. (Explain who, what, where, when, why, and how. Identify and define the type of cyber attack).

4. Formulate a plan of defense against the attack. Based on your research and the summary you wrote, how could this attack have been prevented or quickly stopped? Write your response in the space provided.

5. Discuss your plan with the class. Participate in and provide feedback to others' plans of defense against cyber attack.

6. Turn your completed lab sheet in to your instructor.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

Name _____

Test Antivirus Software

Purpose

The purpose of this activity is to test your current antivirus software.

Objectives

1. Download antivirus tools.
2. Employ antivirus tests.
3. Track the results of each test.
4. Rate the strength of your antivirus program.
5. Participate in a class discussion of antivirus software strength.

Materials

- lab sheet
- device with Internet access

Procedure

1. Name your computer's antivirus tool: _____
2. Download the following antivirus tools:
   a. EICAR (European Institute for Computer Anti-Virus Research) at http://www.eicar.org/86-0-Intended-use.html
   b. Comodo HIPS and Firewall Leak Test Suite at https://personalfirewall.comodo.com/cltinfo.html
   c. Trojan Simulator at http://www.testmypcsecurity.com/securitytests/trojan_simulator.html

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003

3. Run each antivirus tool. Track the results.

   a. What did your antivirus catch? List the results in the space provided.

   b. What did your antivirus miss? List the results in the space provided.

4. Given your results, how strong is your current antivirus? Rate your antivirus program from 1 to 4. (1 = very weak to 4 = very strong)

   a. Rating: _____
   b. What would explain your rating?

5. Participate in a class discussion of antivirus software strength.

6. Turn your completed lab sheet in to your instructor.

Copyright © by CAERT, Inc. | Reproduction by subscription only. | L790003